

The Strategic Architecture Framework

The layer above enterprise architecture which underpins security

James Patrick CITP MBCS

First edition

An open framework. Published for adoption, adaptation, and extension.

Abstract

Enterprise architecture, as practiced, describes how systems behave when their environment cooperates with their purpose. It is a discipline of conditions, capabilities, and constraints under the assumption of friendly operation. This is no longer sufficient. The systems on which government, critical national infrastructure, and defence-adjacent industry depend now operate in an environment that is intermittently and increasingly adversarial - not in the cyber-security sense, which the discipline already addresses, but in the strategic sense, in which lawful, contractual, and politically routine actions by other parties can degrade or withdraw capability without warning. The architectures we have inherited were not designed against this condition because the condition was not present when they were designed.

This paper proposes a Strategic Architecture Framework: a discipline that sits above enterprise architecture and beneath statecraft, concerned with the properties of systems under contest. It establishes a vocabulary, distinguishes the proposed discipline from the adjacent disciplines with which it might be confused, specifies three core artefacts - the jurisdictional architecture drawing, the strategic exposure register, and the contestability rehearsal - and identifies the development of an adequate vocabulary for compositional incidents as the principal open problem facing the field. The framework is presented as open. It is intended to be adopted in whole or in part, adapted to local conditions, and extended by practitioners. It is not a methodology in the procedural sense and it is not a maturity model. It is a set of instruments through which an organisation can come to know what it has actually built.

This second edition adds a chapter examining the relationship between the framework and the adjacent disciplines - TOGAF, SABSA, NIST RMF, operational resilience, and enterprise risk management - and tightens the treatment of compositional incidents in recognition that the development of a mature vocabulary for that class of incident is properly the field's task, not this paper's.

Contents

1. Introduction: the gap above enterprise architecture
2. Foundations: contestability as an architectural property
3. The adjacent disciplines and where they stop
4. The jurisdictional architecture drawing
5. The strategic exposure register
6. The contestability rehearsal
7. Compositional incidents: an open problem
8. Adoption: ninety days, one year, and living with exposure
9. Coda: an open framework

1. Introduction: the gap above enterprise architecture

Every architecture encodes a worldview. The architectures that now underpin government, critical national infrastructure, and defence-adjacent industry encode a particular one. They were built for a permissive decade. They assume that borders are commercial conveniences, that supply chains are optimisation problems, that the relevant timescales for legal and geopolitical change are slower than the timescales for technical change, and that the relationship between operator and provider is permanently cooperative. None of these assumptions were wrong when they were made. All of them are now exposures.

Enterprise architecture, as a discipline, has matured around the management of complexity within cooperative conditions. It is concerned with the alignment of business capability and technical capability, the standardisation of patterns, the rationalisation of estates, and the orderly evolution of systems over time. It does this work well. It is, however, not the right discipline for the question this paper concerns. The question is not how to manage complexity under cooperation. It is how to understand what a system is when the cooperation it depended on is withdrawn.

This is not a new question in the abstract. The defence community has thought about it under the heading of resilience for decades. The legal community has thought about it under the heading of jurisdiction. The political community has thought about it under the heading of sovereignty. What is new is that the question now arises in respect of systems that none of these communities individually designed, and that no one of them is in a position to govern alone. The cloud-native estates on which contemporary critical services depend are composed of legal entities, technical artefacts, model weights, identity systems, and update channels whose properties under contest emerge only at the level of the composition. No single sub-discipline holds the whole picture, and no existing discipline takes responsibility for the picture as a whole.

This paper proposes that the picture as a whole is the proper concern of a discipline that does not yet have a settled name. It calls that discipline strategic architecture. The choice of name is deliberate. The word strategic, as used here, is not aspirational and does not refer to importance or to seniority. It refers, in the original sense, to the conduct of affairs under conditions of contest with other actors who have their own purposes. Strategic architecture is the architecture of systems whose environment includes other intentional actors. It sits above enterprise architecture because it concerns properties of systems that enterprise architecture takes as given, and it sits beneath statecraft because the choices it concerns are exercised by organisations rather than by states.

The paper is organised around three claims. The first is that contestability - the capacity of a system to continue to be operated, by its intended operator, for its intended purpose, when another actor is acting against that purpose - is a distinct architectural property that has been collapsed, in current practice, into resilience and sovereignty, and that the collapse renders it invisible. The second is that the discipline of strategic architecture requires its own artefacts, distinct from those of enterprise architecture, and that three such artefacts can be specified now in sufficient detail to be adopted. The third is that the incident vocabulary on which contemporary operations depend is inadequate to the kind of incident that strategic architecture concerns, and that the development of an adequate vocabulary is an open problem for the field.

Each of these claims invites a reasonable objection. The first claim invites the question of whether contestability is genuinely distinct or whether it is a relabelling of properties that resilience, sovereignty, or risk management already address. The second invites the question of whether the proposed artefacts produce findings that existing instruments would not have produced. The third invites the question of whether compositional incidents are a distinct class or whether they are simply incidents the existing categories have not yet been applied to with sufficient rigour. The paper takes these objections seriously. Chapter three is given over entirely to the first of them. The artefact chapters that follow include worked examples designed to demonstrate the second. The treatment of compositional incidents is offered as an open problem in chapter seven precisely because the third objection is not yet decisively answerable.

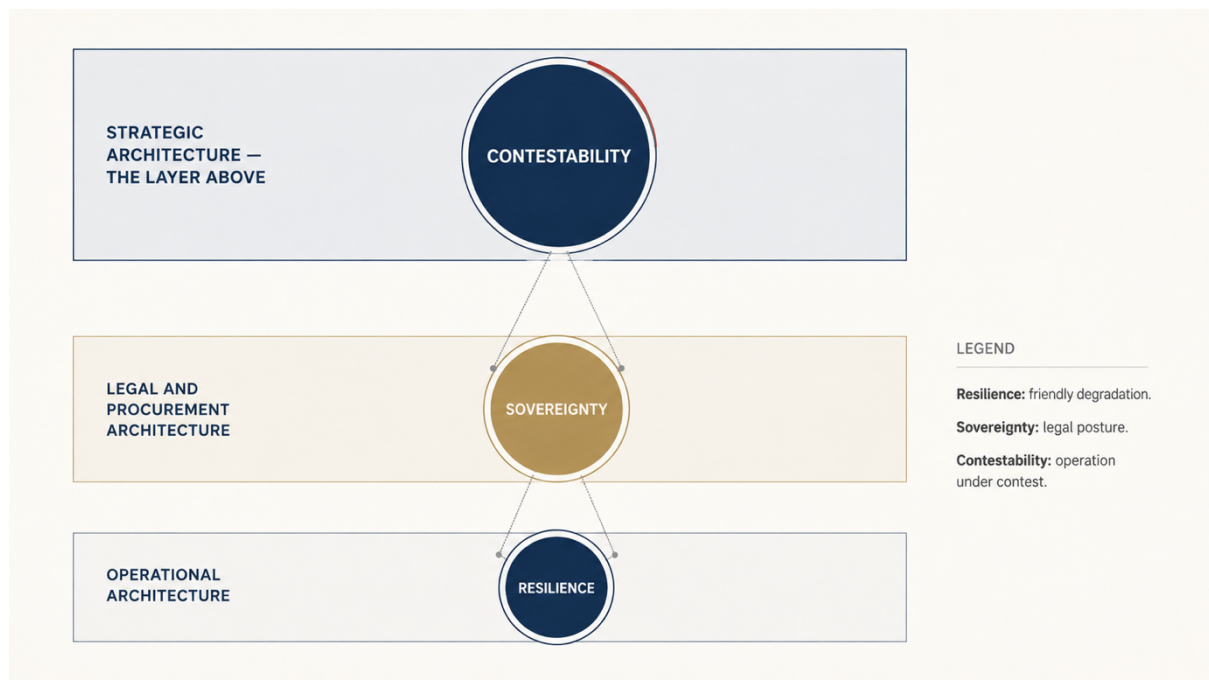
The paper does not offer solutions in the sense of recommended technologies, procurement choices, or vendor strategies. It is concerned with the layer beneath those choices: the practice through which an organisation comes to know what it has actually built, and what the actual properties of that build are under conditions that the build was not asked to anticipate. It assumes a senior reader - a chief technology officer, a chief information security officer, a permanent secretary, a board member with technical responsibility, a head of digital at a critical infrastructure operator - who is concerned with the consequences of those choices but who, in most cases, does not have the instruments through which to examine them.

The framework is offered openly. It is intended to be adopted in whole or in part, adapted to local conditions, and extended by practitioners. It is not a product, not a methodology in the procedural sense, and not a maturity model. It is a set of instruments through which an organisation can come to know what it has actually built. The hope is that the field will

improve upon it. The expectation is that, in places, it is wrong. Better tools are welcome. The condition the framework addresses is not waiting for them.

2. Foundations: contestability as an architectural property

Before the framework's artefacts can be specified, the vocabulary in which they will be interpreted must be repaired. Three terms have collapsed into one another in current usage, and the collapse is part of what allows the conditions this paper concerns to remain invisible. The terms are resilience, sovereignty, and contestability. They describe different properties of systems. They are not interchangeable. The first two are mature concepts with established disciplines. The third is the property this paper takes as its subject.



2.1 Resilience

Resilience describes the behaviour of a system under friendly degradation. A disk fails. A region goes offline. A service throttles. A network link saturates. The conditions are adverse but not adversarial. The environment is not trying to defeat the system; it is merely failing to support it. Resilience engineering - redundancy, replication, graceful degradation, chaos engineering, failover testing - is the discipline of operating well under these conditions. It is a mature discipline with well-developed instruments. Its assumption is that the environment is unreliable. Its method is to add tolerance to the system such that the unreliability of the environment is absorbed without loss of capability.

The implicit assumption of resilience engineering is that the failure of any component is uncorrelated with the failure of any other component, except where the architecture has been explicitly designed to allow correlation. This assumption holds, broadly, for the physical and operational failures that resilience engineering addresses. It does not hold for the

conditions this paper concerns. The events of interest here are correlated by their cause - a single actor, a single decision, a single condition - even when the components affected are diverse, distributed, and operationally independent.

2.2 Sovereignty

Sovereignty describes the jurisdictional properties of a system. It is a legal posture. It can be assessed at rest. It records which sovereign authorities have lawful reach into which components of the system, on what grounds, and under what conditions. Sovereignty is a property that exists independent of whether the authority is exercised. A system operated in a particular jurisdiction is subject to the laws of that jurisdiction whether or not anyone has yet invoked those laws against the system.

Sovereignty is necessary but not sufficient. It tells us who has authority. It does not tell us what happens when that authority is exercised against us. It is also, in current practice, often assessed at too coarse a granularity to be useful - at the level of the operator, the data centre, or the contract, rather than at the level of the components and their composition. A system can be operated by a domestically incorporated entity, hosted in a domestic data centre, and contracted under domestic law, while depending on update channels, model weights, identity providers, or control planes whose jurisdictional reach is entirely foreign. The assessment of sovereignty as currently practiced would record such a system as sovereign. The system would not be sovereign in any property that mattered.

2.3 Contestability

Contestability is the property this paper takes as its subject. It is the operational question of whether a system can continue to be operated, by its intended operator, for its intended purpose, when another actor is acting against that purpose. The other actor may be an adversary, in the conventional sense. The other actor may also be a regulator, a court in another jurisdiction, a vendor exercising contractual rights, a parent company responding to political pressure in its home jurisdiction, an identity provider responding to a domestic legal request, or any other party whose actions are lawful in their own context but whose effects are adverse in ours. The mechanism varies. The question is the same.

Three features of contestability are worth establishing now because they govern everything that follows. First, contestability is a property of the composition rather than of the components. Individual components may each be contestable or not contestable in isolation; the question that matters is the contestability of the composition under specific conditions of contest. Second, contestability is not binary. A system may be more or less contestable, in

respect of different conditions, against different actors, on different timescales. The framework will need to record this gradation rather than collapse it. Third, contestability is conditional on the operator. The same system, in respect of the same conditions of contest, may be contestable for one operator and not contestable for another, because contestability depends on the legal, contractual, and operational standing of the party seeking to operate the system as well as on the system itself.

2.4 The strategic architecture layer

These three properties - resilience, sovereignty, contestability - sit at different layers. Resilience is a property of the operational architecture. Sovereignty is a property of the legal and procurement architecture. Contestability is a property of the composition of the two, examined under the assumption that the environment includes intentional actors with their own purposes. The strategic architecture layer is the layer at which the composition is examined. It is not a replacement for enterprise architecture, security architecture, or solution architecture. It is the layer that holds the questions those disciplines, individually, are not equipped to ask.

Strategic architecture, as proposed here, has four distinguishing concerns. It concerns the jurisdictional topology of systems as an architectural property of equal weight to the technical topology. It concerns the identification of architectural assumptions whose activation by external actors would degrade capability. It concerns the rehearsal of system behaviour under conditions of contest. And it concerns the recognition and recording of incidents that exist only at the level of the composition, not at the level of any component. These four concerns map onto the four substantive chapters that follow the next. They are not exhaustive of strategic architecture as a discipline; they are the concerns that can be specified now in sufficient detail to be adopted.

Before turning to those concerns, the next chapter examines the adjacent disciplines with which strategic architecture might be confused, and demonstrates the structural reasons each stops short of the questions this framework takes up. The purpose is not to diminish those disciplines. They are mature, valuable, and necessary. The purpose is to establish, with precision, where they end and where strategic architecture begins.

3. The adjacent disciplines and where they stop

The reasonable first objection to the proposal in this paper is that the discipline it describes is not new. Architecture frameworks already exist. Security frameworks already exist. Risk management frameworks already exist. Operational resilience frameworks already exist. Each addresses some part of what strategic architecture claims as its subject, and the burden of proof lies with the proposal, not with the existing frameworks, to show that something genuinely new is being claimed.

This chapter takes that burden seriously. It examines five adjacent disciplines - TOGAF, SABSA, the NIST Risk Management Framework, operational resilience as established in financial-sector regulation, and enterprise risk management - at their strongest rather than at their weakest. In each case the question asked is the same. What does this discipline do well? What does it not address, and why does it not address it? And what specifically would it have missed in a case where strategic architecture, as proposed here, would have caught the exposure? The chapter concludes by examining what is shared across all five disciplines and what is structurally absent.

The argument is not that the adjacent disciplines are inadequate. They are adequate for what they were designed to do. The argument is that the conditions that strategic architecture concerns lie outside what they were designed to do, and that the gap is structural rather than incidental. Extending any of the adjacent disciplines to cover the gap would require changing the discipline's foundational assumptions, at which point it is no longer the same discipline. It is, instead, what this paper calls strategic architecture.

3.1 TOGAF and enterprise architecture frameworks

TOGAF, in its mature form, is a comprehensive framework for the practice of enterprise architecture. Its strengths are well established. It provides a method - the Architecture Development Method - for the orderly evolution of architectures over time. It provides a content framework for organising architectural artefacts. It provides a capability framework for establishing and maintaining an architecture practice. It provides a reference model and a continuum for managing the relationship between generic and specific architectures. Its vocabulary is widely shared across the profession, and its adoption permits architectural conversations to proceed with common reference.

What TOGAF does not address, and was not designed to address, is the question of how an architecture behaves when its environment becomes adversarial in the strategic sense. The Architecture Development Method assumes that requirements are gathered, that

stakeholders are identified, and that the resulting architecture is evolved toward a defined target state. The framework's treatment of risk, in its risk management section, is the conventional treatment of risk as probability multiplied by impact, with mitigations defined against identified threats. The threats considered are predominantly internal to the architectural endeavour itself - schedule risk, capability risk, integration risk - and where external threats are considered, they are considered in their cooperative form: regulatory change to which the architecture must adapt, market change to which it must respond, technological change which it must absorb.

The structural reason for this limit is that TOGAF was developed for environments in which the principal architectural challenge was complexity, not contest. Its assumption is that the stakeholders are aligned in their interest in the architecture's success and that the environment is a context to which the architecture must respond rather than an opponent against which the architecture must endure. This assumption was appropriate for the conditions of TOGAF's development. It is incomplete for the conditions strategic architecture addresses.

A specific case illustrates the gap. Consider a TOGAF-conformant architecture for a national case management system, with a target state involving a major hyperscaler's managed services for compute, storage, identity, and machine learning. The Architecture Development Method would have produced a defensible architecture: requirements traced, stakeholders consulted, target state defined, gap analysis conducted, migration planned. The architecture's risk register would record technical risks, integration risks, and conventional security risks. What it would not record - because TOGAF does not direct attention to it - is the exposure constituted by the composition of foreign-jurisdictional control planes, foreign-jurisdictional identity infrastructure, and foreign-jurisdictional model provenance into a single capability whose properties under lawful action by the hyperscaler's parent jurisdiction have never been examined. TOGAF is not silent on this exposure because it has been overlooked. It is silent because the discipline does not direct attention to it. The same architecture, examined through the framework proposed here, would have produced a jurisdictional architecture drawing in which the exposure is plain on the page.

3.2 SABSA and security architecture

SABSA is the most developed security architecture framework in current practice. Its layered model - contextual, conceptual, logical, physical, component, operational - provides a more sophisticated treatment of architectural security than is available in any of the general frameworks. Its strengths include the explicit derivation of security requirements from

business attributes, the rigorous treatment of security services and mechanisms, and the integration of security architecture with broader architectural decisions rather than its treatment as a layer applied after the fact.

SABSA's risk model is also more sophisticated than the conventional treatment. It addresses threat agents, their capabilities, their motivations, and the attack paths through which they may realise threats. It supports the modelling of security in terms of business risk rather than purely technical risk. For organisations adopting SABSA rigorously, the discipline produces architectures with a defensible security posture against the threat agents the model considers.

The limit of SABSA, for the purposes of this paper, lies in its threat model. The discipline treats threats as adversarial actions taken by threat agents pursuing recognisable attacker objectives - confidentiality compromise, integrity compromise, availability compromise - through recognisable attacker means. This is the correct discipline for the threats SABSA addresses. It is not the discipline for the conditions strategic architecture concerns, because the actions of interest here are not adversarial in the SABSA sense. A vendor exercising a contractual right is not a threat agent. A court issuing a lawful order in another jurisdiction is not a threat agent. A regulator amending the terms under which a service may be provided is not a threat agent. SABSA's risk model does not extend to these actors because they do not satisfy its definition of threat.

The structural reason for this limit is that SABSA was developed within the security profession, and the security profession has a specific, defensible, and narrow definition of threat. Extending SABSA to encompass lawful adverse action by non-malicious actors would dilute the precision that gives the framework its analytic power. The discipline correctly retains its narrow definition. What is needed is not a broader SABSA. What is needed is a different discipline that addresses the actors and actions SABSA correctly excludes from its scope.

A specific case illustrates the gap. A SABSA-conformant architecture for the same case management system would produce a comprehensive treatment of security against the threat agents considered - external attackers, malicious insiders, opportunistic intruders. The architecture's threat model would not include the vendor's parent company complying with a lawful order in its home jurisdiction, because that party is not, in SABSA's terms, a threat agent. The architecture would, as a result, accept dependencies on components whose contestability under that condition is not assessed. The framework proposed here, through the strategic exposure register, would record the dependency as an exposure with a named

actor class and a named mechanism, and would do so without requiring the SABSA threat model to be distorted to accommodate it.

3.3 NIST Risk Management Framework

The NIST Risk Management Framework, as developed in SP 800-37 and its associated publications, is the most rigorous of the publicly available risk management frameworks for information systems. It provides a structured process for categorising systems, selecting controls, implementing them, assessing their effectiveness, authorising the system to operate, and monitoring continuously. Its underlying catalogue of controls, in SP 800-53, is the most comprehensive available and is referenced widely across both public and private sectors. Its tailoring guidance permits the framework to be applied across systems of widely varying sensitivity and complexity.

The framework's strength is the rigour of its process. Its weakness, for present purposes, is twofold. First, the catalogue of controls is, despite its comprehensiveness, a catalogue of mitigations against identified threats. The threats considered are predominantly those of confidentiality, integrity, and availability compromise through technical or operational means. Controls against lawful adverse action by non-adversarial parties are largely absent from the catalogue because such action does not fit the framework's threat model. Second, the authorisation process treats authorisation as a point-in-time judgement that the residual risk is acceptable. The framework's continuous monitoring component addresses changes to the system and its threat environment, but the threat environment as conceived is, again, the threat environment of confidentiality, integrity, and availability compromise.

The structural reason for this limit is that the framework was developed for the protection of information and information systems against confidentiality, integrity, and availability compromise. That is its scope. It is excellent within that scope. The conditions strategic architecture addresses are largely outside that scope - they are conditions in which capability is degraded or withdrawn through means that do not compromise confidentiality, integrity, or availability in the framework's sense. A vendor terms change that alters a model's behaviour does not compromise the integrity of the model in the technical sense; it changes the model. A court order that compels disclosure of operational data to a foreign authority does not compromise confidentiality in the sense the framework addresses; it routes confidentiality differently than was assumed.

A specific case illustrates the gap. A NIST RMF-conformant authorisation for the case management system would assess the system against the controls in SP 800-53, document

the residual risks against the threats considered, and authorise operation at the appropriate impact level. The authorisation would not consider - because the framework does not direct attention to it - the question of what would happen to the system's authorising posture if the foundation model integrated into its triage component were updated by its provider in a way that altered case outcomes. The system's authorisation would remain in effect. The system's behaviour would have changed. The framework proposed here, through the contestability rehearsal, would have rehearsed precisely this condition and would have recorded the residual operating posture explicitly.

3.4 Operational resilience as established in financial sector regulation

Operational resilience, as established in financial sector regulation in the United Kingdom and increasingly elsewhere, is among the more recent and more rigorous of the adjacent disciplines. The regulatory framework requires firms to identify important business services, set impact tolerances for the disruption of those services, map the resources required to deliver them, and demonstrate the ability to remain within impact tolerance through severe but plausible scenarios. The discipline has matured rapidly under regulatory pressure and is, in many respects, the closest of the adjacent disciplines to what this paper proposes.

The discipline's strengths include the orientation around business services rather than systems, the explicit articulation of impact tolerances, the requirement to map dependencies including third-party dependencies, and the requirement to test through plausible scenarios. The framework has driven a quality of architectural understanding in many regulated firms that exceeds what the firms previously possessed, and which exceeds what is typical in non-regulated sectors.

The limit of the discipline, for present purposes, lies in the regulatory definition of plausible scenarios. The scenarios required are severe but plausible disruptions to business services. The disruptions considered are predominantly those of operational failure - outage of a third-party provider, failure of a critical system, loss of a key facility, cyber incident affecting capability. The scenarios are stress scenarios for resilience in the established sense, not contestability scenarios in the sense this paper proposes. Where lawful adverse action by other parties is considered at all, it is considered through the lens of supplier failure or supplier withdrawal, not through the lens of supplier action under the laws of the supplier's home jurisdiction or under the supplier's own contractual rights.

The structural reason for this limit is that the regulatory framework was developed in response to a specific class of incident - operational disruption to critical financial services -

and the scenarios it requires are calibrated to that class. The framework has driven significant improvements in operational resilience. It does not address contestability because contestability is not in its scope, and broadening its scope would dilute the regulatory clarity that gives the framework its effect. The discipline correctly retains its operational focus. The conditions strategic architecture addresses sit outside that focus.

A specific case illustrates the gap. An operational resilience assessment of a regulated firm's case management equivalent - a customer onboarding service, for example - would map the resources required, identify third-party dependencies, set impact tolerances, and demonstrate continued operation under severe but plausible disruption. The disruption scenarios would include cloud provider outage, identity provider outage, model service outage. They would not, typically, include the scenario in which the cloud provider's parent jurisdiction compels the provider to alter the service in a way that remains operationally available but is no longer suitable for the firm's purposes. That scenario does not satisfy the regulatory definition of disruption. The framework proposed here, through the contestability rehearsal, would address precisely that scenario.

3.5 Enterprise risk management

Enterprise risk management, as practiced in the form codified in COSO and similar frameworks, is the broadest of the adjacent disciplines and the one with the longest history. It provides a comprehensive approach to the identification, assessment, treatment, and monitoring of risks across an organisation, integrated with strategy and performance. Its strengths include its breadth, its board-level positioning, and its integration with strategic decision-making.

The discipline's limit, for present purposes, is the universal limit of risk management as conventionally practiced: it treats risks as events to which probabilities and impacts can be assigned. This is the correct treatment for the risks the discipline was designed to address - operational risks, financial risks, compliance risks, strategic risks of the conventional kind. It is not the correct treatment for the exposures strategic architecture concerns, which are not events but properties of an architecture that activate under conditions external to the organisation. Forcing such exposures into the conventional risk register requires assigning probabilities that the practitioner does not have a defensible basis for assigning, with the result that either the probabilities are guessed and the register is misleading, or the exposures are excluded because they do not fit the register's structure.

The structural reason for this limit is that risk management's analytic engine is the probability-impact pair. Where probability can be estimated with discipline - from historical frequency, from actuarial models, from informed expert judgement - risk management is powerful. Where probability cannot be estimated with discipline - because the events are conditional on the actions of identifiable parties whose decisions are not governed by probability distributions - the analytic engine breaks down. Strategic exposures are predominantly in the second category. The framework proposed here, through the strategic exposure register, replaces the probability-impact pair with the actor-mechanism-residual capability triple, which is appropriate for conditions where probability cannot be estimated but where the conditions, actors, and consequences can be specified.

3.6 What is shared, and what is structurally absent

Across the five adjacent disciplines, three commonalities are evident. Each is a mature discipline within a defined scope. Each has its own analytic engine appropriate to that scope. Each was developed for conditions in which the principal challenge was complexity, failure, malicious attack, operational disruption, or probabilistic uncertainty - but not lawful contest between actors with competing legitimate interests. The disciplines are not deficient. They are correctly bounded.

What is structurally absent across the disciplines is the treatment of capability as a property held conditional on the continued cooperation of identifiable other parties whose decisions are governed by their own interests, their own legal regimes, and their own commercial circumstances. The disciplines treat cooperation as the default condition. Departures from cooperation are treated as failures, attacks, disruptions, or risks - categories that each map to one of the disciplines but none of which captures the structure of lawful, contractual, or politically routine action by another party. Strategic architecture, as proposed here, takes that absence as its subject. The discipline is needed not because the existing disciplines are inadequate but because they are correctly bounded such that the question lies outside all of them.

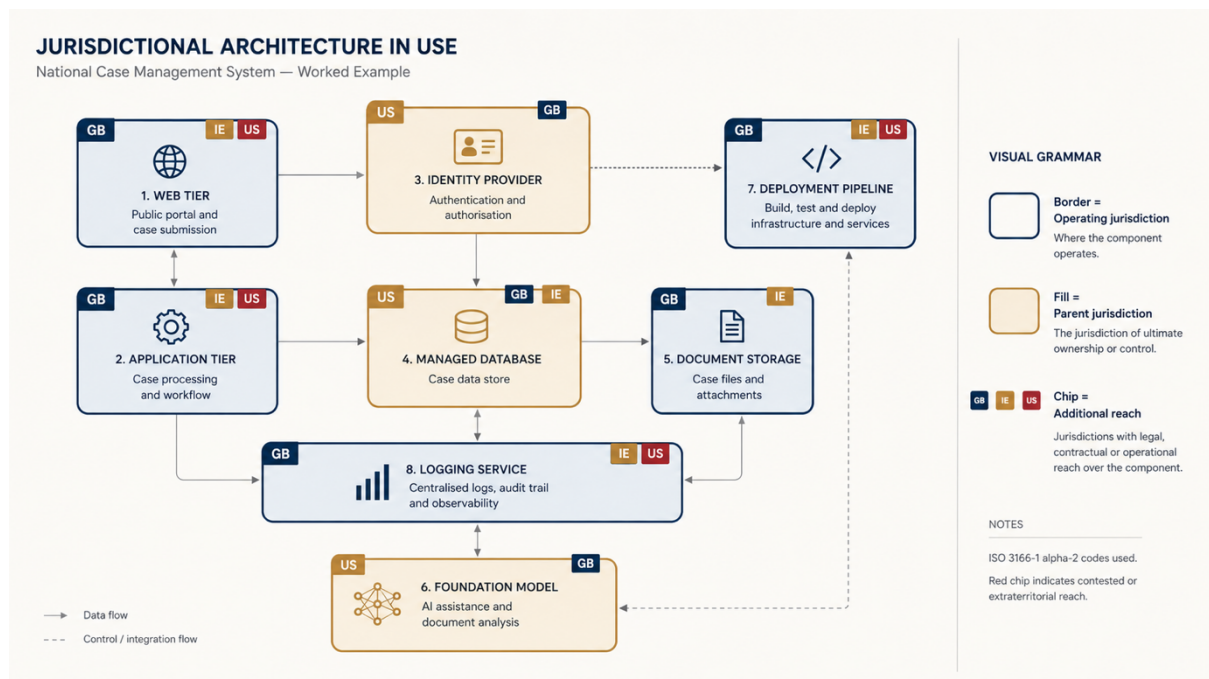
The legitimate question that remains is whether the discipline this paper proposes could be developed by extending one of the adjacent disciplines rather than by establishing a new layer. The proposal of this paper is that the latter is more honest. Each adjacent discipline has a foundational assumption that would have to be revised - TOGAF's assumption that stakeholders are cooperating, SABSA's definition of threat agents, NIST RMF's catalogue of mitigations against confidentiality-integrity-availability compromise, operational resilience's definition of disruption, enterprise risk management's probability-impact analytic engine.

Revising any of these would not extend the discipline. It would replace it. Naming the new layer permits the adjacent disciplines to continue doing what they do well, and permits the new questions to be examined with instruments appropriate to them.

The remaining chapters specify those instruments.

4. The jurisdictional architecture drawing

The first artefact of the Strategic Architecture Framework is the jurisdictional architecture drawing. It is the simplest of the three artefacts to specify and the most foundational. Without it, the other artefacts have no surface on which to operate. With it, the questions that strategic architecture concerns become tractable. The drawing is not a replacement for the technical architecture diagram. It is an overlay. Its purpose is to make visible, at the same resolution as the technical view, the legal and political reach into each component of a system.



4.1 Method

The drawing is produced from the existing technical architecture diagram by a three-pass annotation. The technical diagram is taken as authoritative for the components and their relationships. The annotation does not alter the technical diagram; it adds a parallel layer of information that can be inspected in conjunction with it.

In the first pass, each component is annotated with the jurisdiction of the legal entity that operates the component. This is the entity that has day-to-day operational responsibility - the cloud provider for a managed service, the software vendor for a SaaS component, the internal team for a self-operated component, the identity provider for an identity service. The jurisdiction recorded is the place of incorporation of the operating legal entity, not the location of the data centre, not the location of the contract, and not the location of the customer. The distinction matters because operational decisions are taken at the level of the

operating entity and are subject to the law of its place of incorporation regardless of where the underlying physical infrastructure happens to be.

In the second pass, each component is annotated with the jurisdiction of the legal entity that owns the parent of the operating entity, if different. For a wholly-owned subsidiary, this is the jurisdiction of the parent company. For a more complex corporate structure, it is the jurisdiction of the entity at the head of the controlling chain. This pass captures the corporate reach: the jurisdiction whose law governs strategic decisions about the operating entity, including decisions to divest, withdraw, restructure, or comply with parent-jurisdiction legal orders. In many cases the first and second pass annotations are identical. In a meaningful number of cases they are not, and the divergence is itself a finding.

In the third pass, each component is annotated with any additional jurisdiction that has lawful reach into the component through extraterritorial legislation, treaty obligation, court order with cross-border effect, or any other recognised legal mechanism. This pass is the hardest of the three and the one most likely to require external legal advice. It is also the pass that most often reveals exposures that the first two passes do not. A component operated by a domestic entity, owned by a domestic parent, may nonetheless be reachable by foreign authority through specific legal instruments. The drawing must record these reaches where they exist, even where their activation is judged unlikely.

4.2 Notation

A consistent visual grammar is essential to the drawing's utility. The recommended notation is as follows. Each component on the technical diagram is given a coloured border indicating the operating jurisdiction, a coloured fill indicating the parent jurisdiction, and one or more tags indicating any additional jurisdictions with lawful reach. Where the operating and parent jurisdictions are identical, the border and fill share a colour. Where they differ, the contrast is visible at a glance. Where additional jurisdictions are present, they are shown as small flags or codes attached to the component, with the legal instrument naming the source of reach recorded in a legend or annotation.

A small number of conventions improve legibility. Jurisdictions are referenced by ISO 3166-1 alpha-2 codes for compactness. Supranational reaches, where relevant, are referenced by a separate convention agreed within the organisation. Where a jurisdiction is uncertain - and uncertainty is common in respect of complex corporate structures or contested legal instruments - the convention is to record the uncertainty explicitly using a question mark or a hatched fill rather than resolving it falsely to the most likely answer. The discipline of

recording uncertainty is one of the most valuable aspects of the practice. A drawing that resolves all uncertainty is a drawing that has been read too quickly.

4.3 A first worked example: a national case management system

Consider a fictional but plausible system: a national-level case management application used by a domestic public-sector body. The technical architecture diagram shows the following components. A web tier hosted on a major hyperscaler's domestic region. An application tier on the same provider. A managed relational database also on the same provider. An identity provider integrated through a federated identity service. A document storage service using the same hyperscaler's object storage. A foundation model accessed through the hyperscaler's managed AI service, used for automated triage of case correspondence. A managed logging and monitoring service. A continuous deployment pipeline hosted on a third-party platform. The technical diagram shows these components, their network paths, their data flows, and their identity boundaries.

The jurisdictional architecture drawing, produced by the three-pass annotation, would reveal the following. The web tier, application tier, database, and storage are operated by a domestic subsidiary of the hyperscaler, owned by a parent in another major jurisdiction, with additional reach available to that parent jurisdiction through extraterritorial legislation. The identity provider is operated by the same hyperscaler subsidiary, with the same parent jurisdiction, and with the additional property that authentication decisions are dependent on a control plane operated centrally and not in the domestic region. The foundation model is provided by a third party in a different major jurisdiction, with its own parent jurisdiction reach, and is updated on a schedule controlled by that third party. The deployment pipeline is operated by yet another entity, in yet another jurisdiction, with its own parent reach.

The technical diagram shows a cleanly designed domestic application. The jurisdictional architecture drawing shows a system with reach from at least three foreign jurisdictions, two of which can act independently of the domestic operator's contractual relationship with the hyperscaler. Neither diagram is wrong. They show different properties of the same system. The point of producing the second drawing is not to indict the first. It is to make the second set of properties visible alongside the first, so that the system can be reasoned about as it actually is rather than as the technical diagram alone would suggest.

4.4 A second worked example: a critical national infrastructure control system

The case management example is illustrative but the components are largely interchangeable across organisations. A second example, drawn from a different domain and at higher

complexity, demonstrates the practice in a context where the exposures are more consequential and the corporate structures more involved.

Consider a control system for a piece of critical national infrastructure - a power transmission network, a water treatment facility, or a transport signalling system. The technical architecture shows the following. A supervisory control and data acquisition layer running on industrial control system hardware from a major equipment vendor. A historian database for time-series data, running on commodity infrastructure operated by the infrastructure owner. An asset management system running as software-as-a-service from a vertical specialist. A predictive maintenance service that consumes data from the historian and produces recommendations, provided by a separate vendor and incorporating a foundation model from a third party. An operator interface running on engineering workstations. A remote support connection to the equipment vendor used for diagnostics and software updates. A regulatory reporting interface to the relevant national regulator.

First-pass annotation reveals the operating jurisdictions. The control hardware is operated by the domestic subsidiary of the equipment vendor for warranty and support purposes. The historian is operated by the infrastructure owner in the domestic jurisdiction. The asset management service is operated by the vertical specialist, whose entity of contract is in a friendly allied jurisdiction. The predictive maintenance service is operated by another vendor in a different jurisdiction. The foundation model provider is in yet another jurisdiction. The operator interface is operated domestically. The remote support connection is operated by the equipment vendor, with the support engineers physically located across multiple jurisdictions depending on the time of day.

Second-pass annotation reveals the parent jurisdictions. The equipment vendor's parent is in a major industrial jurisdiction with significant export control and strategic technology regulation. The vertical specialist's parent is, after recent acquisition, in a different jurisdiction than the operating entity. The predictive maintenance vendor was acquired six months previously by a holding company in a third jurisdiction; the operating entity has not changed but the parent reach has. The foundation model provider's parent is in the same jurisdiction as the foundation model's operating entity but is subject to specific strategic technology regulations of that jurisdiction.

Third-pass annotation reveals the additional reaches. The equipment vendor's parent jurisdiction has enacted legislation in the past three years extending lawful reach over critical infrastructure technology exports. The vertical specialist's new parent jurisdiction has data protection legislation that may, under specific conditions, compel disclosure of system access

logs to its domestic authorities. The foundation model is subject to its operating jurisdiction's strategic technology regulations, which permit the jurisdiction's authorities to compel modification of the model's behaviour under certain national security conditions.

The technical diagram of this system is, in the view of its operators, a domestic critical infrastructure control system protected by the conventional security architecture and operated by the infrastructure owner. The jurisdictional architecture drawing shows a system in which six distinct foreign jurisdictions have some form of lawful reach into different components, in which three of those reaches have changed in the previous twelve months without the operator's notice through corporate acquisitions and regulatory developments, and in which the composition of these reaches has never been examined as a single property of the system. The composition is the strategic concern. No individual component is, in itself, an unmanageable exposure. The composition is a different matter.

This second example is more involved than the first deliberately. The practice of producing the drawing scales with the complexity of the system. The discipline does not. The three-pass annotation is the same. What changes is the volume of legal advice required, the number of jurisdictions involved, and the rate at which the drawing requires re-examination as corporate structures and legal landscapes change. Organisations operating systems of this complexity should expect the drawing to be a continuously maintained artefact rather than a periodic deliverable.

4.5 Common patterns

Several patterns recur across organisations producing the drawing for the first time, and recording them in advance assists practitioners in recognising what they are seeing. The first is the jurisdictional cluster, in which all components are operated by entities of a single foreign jurisdiction, often without the organisation having previously recognised this as a feature of the design. The second is the jurisdictional spread, in which different components are operated by entities of different foreign jurisdictions, creating a composite reach that no single contract addresses. The third is the hidden control plane, in which the apparent jurisdictional location of a component is contradicted by the location of the control plane through which the component is actually administered. The fourth is the unobservable model, in which a foundation model or other statistical artefact has been integrated into a decision pipeline without provenance information sufficient to record its jurisdictional reach at all. The fifth, evident in the second worked example, is the drift through acquisition, in which the parent jurisdiction of a component changes without alteration to the operating entity,

contract, or technical architecture, and where the change is therefore invisible to all conventional architectural review.

Each pattern indicates a class of exposure that the strategic exposure register, addressed in the next chapter, will examine in detail. The drawing's purpose is not to assess the exposures. Its purpose is to make them visible, in their composition, on a single artefact, at a resolution sufficient for the assessment to be conducted.

4.6 Maintenance and governance

The drawing is not a one-time artefact. Like the technical architecture diagram, it requires maintenance. The maintenance burden is, however, of a different character. The technical diagram changes when the technical architecture changes. The jurisdictional drawing changes whenever the technical architecture changes, but also whenever the corporate structure of any operator changes, whenever a relevant legal instrument is enacted or amended, whenever a contract is renegotiated, and whenever a component is updated in a way that alters its dependencies. The governance of the drawing should reflect this. A single architectural function should hold accountability for the drawing's currency. Quarterly review, with formal sign-off at the level of the chief technology officer or equivalent, is a defensible minimum.

The drawing should be classified at a level commensurate with the sensitivity of what it reveals, which is often higher than the classification of either the technical diagram or the legal advice considered separately. The composition discloses more than the parts. Practitioners should be alert to this in particular when sharing the drawing across organisational boundaries, including with auditors, regulators, and partners.

5. The strategic exposure register

The risk register is among the most mature instruments in enterprise governance. It is also, in its current form, badly suited to the exposures that the Strategic Architecture Framework concerns. The conventional risk register records risks as events with a likelihood, an impact, and an owner. The exposures of interest here are not events. They are properties of an architecture that activate under specified conditions. They have no probability in the actuarial sense because they are not random; they are conditional on the actions of identifiable other parties whose decisions are not governed by the probability distributions on which actuarial reasoning depends.

The strategic exposure register is a complementary instrument. It does not replace the risk register. It sits alongside it, and it records different things. Its discipline is to make visible, at the level of governance, the structural exposures that follow from the jurisdictional architecture and the assumptions on which the architecture depends. Its output is not a risk score. Its output is a description of the conditions under which capability would be degraded or withdrawn, the parties who could activate those conditions, and the operating posture that would remain.

5.1 Structure

Each entry in a strategic exposure register has the following fields. The list is not arbitrary; each field exists because it captures information that the conventional risk register does not, and the absence of any field renders the entry significantly less useful.

- Identifier and title. A unique reference and a short descriptive name.
- Component or composition. The element or arrangement of elements of the architecture to which the exposure attaches, with explicit reference to the jurisdictional architecture drawing.
- Architectural assumption. The condition whose continued holding the architecture depends upon, and whose ceasing to hold would activate the exposure. The assumption is stated as a positive proposition, in the present tense.
- Actor class. The class of party capable of causing the assumption to cease to hold. Standard classes include adversary, regulator, court, vendor, parent, partner, internal actor, and natural event. Compound classes are permitted where necessary.
- Mechanism. The means by which the actor would or could cause the assumption to cease to hold. This is a description, not a forecast. It records how the exposure would be activated, not whether it will be.

- **Observable signature.** The signs, if any, by which activation of the exposure could be detected by the operator. This field is frequently blank on first attempt, and the blankness is itself the finding.
- **Operational consequence.** What the organisation would no longer be able to do, expressed in terms of capability rather than of technology. This field describes the loss, not its cause.
- **Residual capability.** What the organisation could still do, by whom, with what authority, and for how long. This field is the one that most often reveals the gap between assumed and actual operating posture under contest.
- **Owner and review cadence.** The accountable role for monitoring the exposure and the schedule on which the entry is reviewed.

5.2 The discipline of completion

The discipline of completing a strategic exposure register is more valuable than the document it produces. Most entries, on first attempt, will be incomplete. The observable signature field, in particular, will often be blank. The residual capability field will often be more speculative than the practitioner would wish. Both are findings, not deficiencies.

A blank observable signature field indicates an exposure for which the organisation has no detection capability. This is not a reason to leave the entry off the register. It is a reason for the entry to exist, because it identifies a gap that no other instrument is currently capturing. An entry with a blank observable signature cannot appear on a conventional risk register, because the conventional register assumes the risk is something that happens, and a thing that cannot be observed cannot be recognised as having happened. The strategic exposure register exists to hold precisely these entries.

A speculative residual capability field indicates that the organisation does not know what it would still be able to do if the exposure were activated. This too is a finding. The proper response is not to refine the speculation. The proper response is to recognise that the operating posture under contest has not been rehearsed, and to schedule a rehearsal. The contestability rehearsal, addressed in the next chapter, is the instrument through which speculative residual capability becomes empirically grounded residual capability.

5.3 Two worked examples

Examples improve specification more than further description. Two illustrative entries follow. They are stylised; real entries will be more specific and longer. They are sufficient to show what the discipline of a good entry looks like.

Example entry: foundation model update channel

Identifier and title: SE-014 - Foundation model update channel exposure.

Component or composition: The triage component of the case management system, as recorded in jurisdictional drawing v2.3, comprising the foundation model accessed through the managed AI service and the downstream pipelines that consume its outputs.

Architectural assumption: The behaviour of the foundation model is stable across the operational lifetime of the system, such that decisions made today and decisions made tomorrow are governed by the same statistical properties.

Actor class: Vendor.

Mechanism: Routine model update under the vendor's standard terms, which permit modification of model weights without operator notification, advance approval, or version pinning beyond a short rollback window.

Observable signature: None directly available. Indirect signals - drift in downstream decision distributions, change in confidence calibration, alteration of refusal patterns - would become apparent only through dedicated monitoring not currently implemented.

Operational consequence: Loss of decision consistency across cases handled before and after the update, with attendant fairness, auditability, and legal exposure if challenged. Cases adjudicated on the basis of differing model behaviour cannot be assumed to be comparable.

Residual capability: The system can continue to process cases, but the assumption of behavioural stability cannot be defended. A manual fallback path exists in principle but has not been exercised at scale and is unlikely to handle current case volumes.

Owner and review cadence: Head of AI governance. Quarterly review, with immediate review on any change to the vendor's standard terms.

Example entry: identity provider control plane

Identifier and title: SE-027 - Identity provider control plane exposure.

Component or composition: The identity service component as recorded in jurisdictional drawing v2.3, comprising the federated identity provider and the directory service on which administrative actions depend.

Architectural assumption: Authentication and administrative actions on the identity service remain available to the operator at the operator's discretion, governed by the operator's policies.

Actor class: Parent jurisdiction (legal compulsion of vendor parent under domestic law of parent jurisdiction).

Mechanism: A lawful order, in the parent jurisdiction of the identity provider, requiring the vendor parent to alter, suspend, or compel disclosure of authentication state for a class of accounts. The vendor parent's compliance with such an order is required under its own law and is not a contractual matter between the operator and the vendor subsidiary.

Observable signature: Possibly none. An authentication suspension would be visible operationally; an alteration or disclosure of authentication state would not necessarily be visible at all, depending on the order's terms.

Operational consequence: For an authentication suspension affecting administrative accounts, loss of ability to manage the identity tier. For a disclosure or alteration of authentication state, loss of confidentiality of administrative actions and possible loss of integrity of audit trails.

Residual capability: Limited. An emergency administrative path exists in documentation but its dependency on the same identity tier has not been audited. The break-glass procedure has been tested for cyber incident scenarios but not for the scenario in which the identity provider itself is the source of the incident.

Owner and review cadence: Chief information security officer. Semi-annual review, with immediate review on any significant change in the legal landscape of the parent jurisdiction.

5.4 Relationship to existing risk instruments

The strategic exposure register does not replace, supersede, or compete with the risk register, the threat register, the control register, or any other instrument of enterprise risk governance. It complements them. Specifically, it captures exposures whose character makes them ill-suited to the conventional instruments: structural rather than event-based, conditional on the actions of identifiable parties rather than probabilistic, and frequently lacking the observable signatures on which detection-based controls depend.

An organisation adopting the framework should expect tension at the interface between the strategic exposure register and the conventional risk register. Some entries will appear in both, treated as different aspects of the same concern. Some entries on the strategic register will have no analogue on the conventional register and should not be forced into one; the discipline of the framework is precisely to make visible the exposures that the conventional instruments cannot hold. Governance should accept this and resist pressure to harmonise the

instruments into a single artefact, because the harmonisation invariably proceeds by reducing the strategic register to the form of the conventional one, which destroys its analytical value.

5.5 Governance and review

The strategic exposure register is properly an instrument of board-level or equivalent governance. The exposures it records are structural and concern the operating posture of the organisation under conditions that affect the organisation as a whole. Ownership of individual entries sits with appropriate senior accountable roles; ownership of the register as an artefact sits at the highest governance level at which architectural decisions are made. In a corporate context this is the board's risk or audit committee, depending on local convention. In a public-sector context it is the equivalent senior governance body.

Review cadence should be set against the rate of change of the conditions that the register concerns. For most organisations a quarterly review of the register as a whole, with individual entries reviewed on the cadence recorded against them, is appropriate. The register should be reviewed in concert with the jurisdictional architecture drawing, because changes to one frequently imply changes to the other. The contestability rehearsal, addressed next, is the instrument through which the register's entries are stress-tested against operational reality.

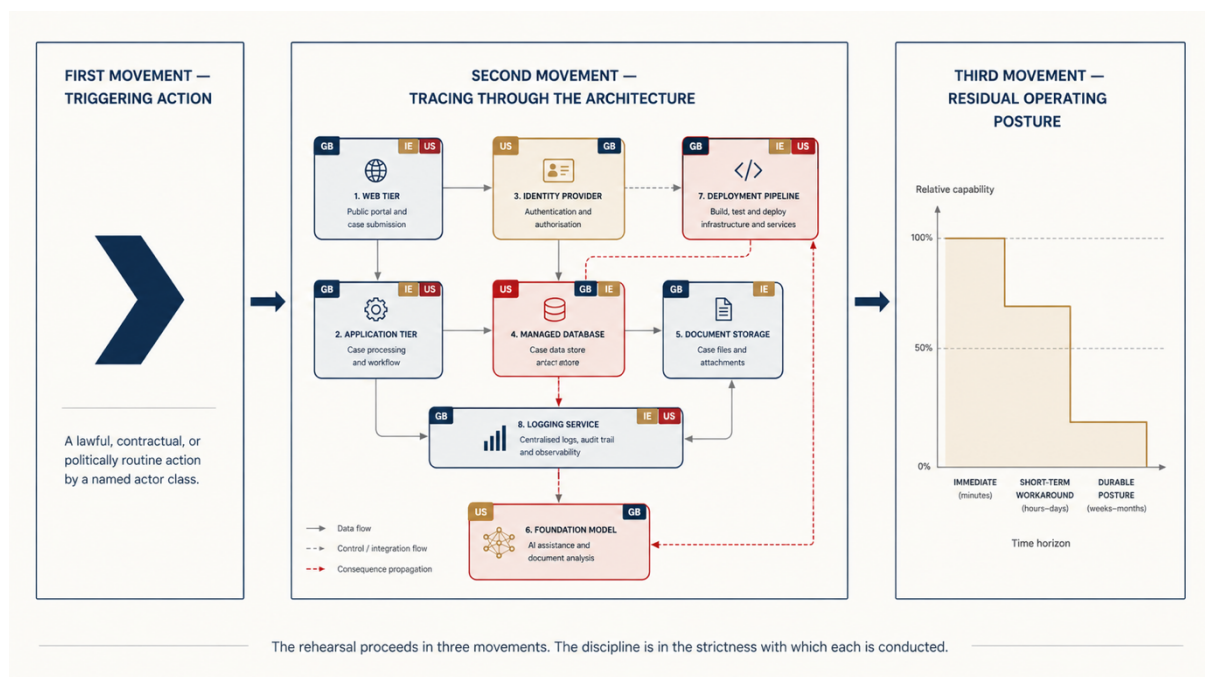
6. The contestability rehearsal

Architectures are tested. Resilience is tested through chaos engineering, failover drills, and disaster recovery exercises. Security is tested through penetration testing, red teaming, and tabletop exercises. These tests are good at what they test. What they do not test is contestability, because they assume the environment is unreliable or adversarial in specific senses that do not capture the conditions of interest here. A chaos engineering exercise assumes friendly degradation. A red team exercise assumes a hostile attacker pursuing recognisable attacker objectives through recognisable attacker means. Neither captures the condition in which a lawful, contractual, or politically routine action by another party degrades or withdraws capability.

The contestability rehearsal is the framework's third artefact, and the one through which the first two are stress-tested against operational reality. It is a structured exercise in which an architecture is examined under the assumption that one or more of its components is acting, or being acted upon, against the operator's interest, by means that are lawful, contractual, or politically routine. The rehearsal is not a red team exercise. It is not a tabletop in the conventional sense. It is a distinct instrument with its own discipline.

6.1 Method

A contestability rehearsal proceeds in three movements. The discipline is in the strictness with which each is conducted; loose rehearsal becomes indistinguishable from speculation and produces no learning.



First movement: the triggering action

The rehearsal begins with the selection of a triggering action. The action must satisfy three criteria. It must be lawful in the jurisdiction in which it is taken, or contractually permitted under the terms governing the relationship in which it arises, or politically routine in the sense that comparable actions have been taken in comparable circumstances by comparable actors. It must not be a malicious act, a cyber-attack, or any other action of the kind already addressed by existing security exercises. And it must be specific: a particular action by a particular class of actor, not a general category.

Sources of plausible triggering actions include: vendor terms updates affecting a category of service; court orders in another jurisdiction requiring compliance by a vendor parent; regulatory rulings altering the conditions under which a category of service may be provided; parent-company strategic decisions affecting subsidiary product lines; identity provider operational changes; foundation model updates; supply chain interruptions through trade restrictions; and policy decisions by other governments affecting the disposition of their domestic firms abroad. The catalogue is open. Practitioners are encouraged to maintain a list of plausible triggering actions appropriate to their context and to rotate through them across successive rehearsals.

Second movement: tracing through the architecture

Once the triggering action is selected, the rehearsal traces its consequences through the jurisdictional architecture drawing and the strategic exposure register. The tracing has three components. First, the identification of the components affected directly - those operated by, owned by, or subject to lawful reach from the actor of the triggering action. Second, the identification of the components affected by composition - those that depend on the directly affected components in ways that the technical architecture diagram makes clear. Third, the identification of which components would notice - which would generate observable signals of the change, which would continue to operate apparently normally despite the change, and which would behave in ways that are operationally undefined.

The tracing is performed live, by a facilitator working with the relevant architectural, operational, and governance roles in the room. It is not performed in advance and presented for review; the value of the exercise is in the working-through, not in the conclusion. Disagreement is welcomed and recorded. The output of this movement is not yet a finding. It is a map of the consequences of the triggering action as understood by the people in the room, with the disagreements and uncertainties recorded as honestly as the agreed positions.

Third movement: the residual operating posture

The third movement identifies the residual operating posture. What can the organisation still do? On what authority? With what assurance? For how long? The questions are answered specifically, in terms of capability rather than technology. The output is a description of the operating posture that would remain under the conditions of the triggering action - including the time-limited posture during any window in which workarounds can be sustained, and the more durable posture once those workarounds have been exhausted.

The residual operating posture is the principal finding of the rehearsal. It is, in most cases, smaller, less certain, and more dependent on individual judgement than the official architecture documentation would suggest. This gap is the value of the exercise. It is the gap that, if documented, changes how procurement, governance, and incident response are conducted. The gap is not, in itself, a deficiency. It is a property of the architecture that has been brought into view, in respect of a specific condition, in a form that can be examined.

6.2 Facilitation

Contestability rehearsals require skilled facilitation. The facilitator's task is not to provide answers; it is to maintain the discipline of the exercise. Three specific facilitation tasks recur. First, preventing the conversation from drifting into red-team territory - the participants will gravitate toward the more familiar mode of considering attacker objectives and means, and the facilitator must repeatedly bring them back to the discipline of lawful, contractual, or routine action. Second, preventing the conversation from drifting into remediation - the participants will gravitate toward what should be done about the exposures revealed, and the facilitator must hold them in the descriptive mode until the residual operating posture is genuinely understood. Third, recording disagreements rather than resolving them; the disagreements are often the richest output.

The facilitator should not be the architect of the system under examination, nor the person accountable for the exposures the rehearsal may reveal. A degree of independence is required. In smaller organisations this independence can be provided by rotation of the facilitator role among senior architectural staff. In larger organisations, or where the exposures are particularly sensitive, an external facilitator with the appropriate clearances and contextual knowledge is appropriate.

6.3 Recording outputs

The output of a rehearsal is recorded in a structured format that connects the rehearsal back to the framework's other artefacts. The recommended structure has the following sections.

The triggering action, recorded in the form used to introduce it. The components affected directly, by reference to the jurisdictional architecture drawing. The components affected by composition. The observability findings - what would and would not be visible. The residual operating posture, in capability terms, with time horizons. The disagreements and uncertainties surfaced during the rehearsal. The implications for entries in the strategic exposure register, including new entries to be created, existing entries to be amended, and existing entries that the rehearsal has empirically supported. The implications for the jurisdictional architecture drawing, where the rehearsal has revealed annotations that should be added, modified, or refined.

The output is not a remediation plan. The framework deliberately separates the description of conditions from the design of responses, because conflating them produces both poorer descriptions and poorer responses. Remediation, where it is pursued, draws on the rehearsal output as one input among many and is conducted through whatever change governance the organisation operates.

6.4 Cadence

A useful cadence is two or three rehearsals per year for any system or system-of-systems of strategic importance, rotating through different classes of triggering action. More frequent rehearsals risk losing the freshness on which the exercise depends. Less frequent rehearsals risk losing the institutional memory of the practice. The cadence should be adjusted to organisational capacity, with the consideration that under-rehearsing is the larger risk for an organisation new to the practice.

7. Compositional incidents: an open problem

The framework's three artefacts are concerned with the description of architectural properties under contest. They are not, in themselves, sufficient for the conduct of incident response. The reason is that the incident vocabulary on which contemporary operations depend is inadequate to the kind of incident the framework concerns. This chapter states the problem and is honest about what it does not yet solve.

This is the part of the framework that is most clearly open. The chapter is shorter in this edition than in the first because the previous treatment overreached. It offered a taxonomy at a stage of the field's development at which a taxonomy cannot yet be defended. The corrected position is that compositional incidents are a real and distinct class of incident, that the existing incident vocabulary does not address them, and that the development of an adequate vocabulary is a task for the field over the coming years. This paper contributes the recognition of the problem and a starting set of practices. It does not yet contribute the vocabulary the field will need.

7.1 The limit of current incident vocabulary

Current incident vocabulary assumes that an incident has a cause, that the cause has an actor, that the actor has an intent, and that the response can be calibrated to the intent. The vocabulary has well-developed categories - cyber-attack, system failure, operational error, supply chain disruption - and each category has its associated incident commanders, runbooks, communications protocols, and lessons-learned procedures. The vocabulary works well for the incidents it was designed to address.

It does not work well for the incidents that strategic architecture concerns. An incident in which individual components are each acting normally and within their own definitions of correct behaviour, but in which the composition of their actions produces a loss of capability at the system-of-systems level, has none of the conventional incident properties in their usual forms. It has actors, but the actors are acting lawfully and routinely. It has causes, but the causes are properties of the composition rather than events. It has consequences, but the consequences are observable only at the level of the composition itself, often only in retrospect, and often only in aggregate. The conventional response calibration - escalate to incident commander, identify the threat actor, contain the incident, eradicate the cause, recover, learn - has no clean application.

7.2 A working definition

A compositional incident is proposed as an incident whose existence, cause, or consequence emerges only at the level of the composition of multiple components, and which is not the result of any single component behaving abnormally with respect to its own specification. The definition is offered as a starting point, not as a settled term. It distinguishes the class from conventional incidents on three properties: the presence of multiple parties each acting lawfully or within contract or within routine professional practice, with no single accountable party; the correlation of the incident by condition rather than by event; and the absence of a single observable signature in any individual component.

These properties are descriptive, not analytic. They identify what makes such incidents difficult to recognise and difficult to respond to within existing frameworks. They do not yet constitute a vocabulary in which compositional incidents can be discussed with the precision that existing incident vocabulary permits for the incidents it addresses. The transition from descriptive identification to analytic vocabulary is the open task. It will be performed by the field over time, through accumulated experience, structured reflection, and the development of practice. It cannot be performed in advance by a single paper.

7.3 What this paper does not claim

Three claims are explicitly withheld in this edition. First, this paper does not offer a taxonomy of compositional incidents. The first edition did so; the categories it proposed were illustrative rather than analytically grounded, and the field will be better served by the development of categories from accumulated case experience than by the entrenchment of categories proposed before that experience exists. Practitioners encountering compositional incidents in the meantime are encouraged to describe what they encounter in their own terms, with attention to the three properties identified above, and to share those descriptions in forums where the field's vocabulary can develop collectively.

Second, this paper does not offer a response model for compositional incidents. The development of an adequate response model depends on a vocabulary that does not yet exist, and any response model proposed in advance of that vocabulary would either be a generalisation from existing models (which would inherit the limitations this paper identifies) or speculation in the absence of case material. Both would be premature.

Third, this paper does not claim that all incidents not addressed by existing categories are compositional incidents. The category should be reserved for incidents that genuinely have the structural properties identified. Misapplying the category to incidents that existing

frameworks could address, with appropriate rigour, would dilute its analytic value before the value has been established.

7.4 What practitioners can do now

Two practices are nonetheless available to organisations that wish to engage with the open problem. They are offered as a beginning, not as a complete response.

The first is the maintenance of a compositional incident log distinct from the conventional incident log. The log captures events that exhibit compositional incident properties even where they do not fit conventional incident categories. The log's structure should be descriptive: what was observed, when, in which components, with what compositional effect, with what response was attempted, with what outcome. Entries should be recorded even when no formal incident was declared, because the inability to declare a formal incident is itself a property of compositional incidents that the log should capture. Over time, an organisation's compositional incident log becomes one of the inputs from which the field's vocabulary will be developed.

The second is the inclusion, in the contestability rehearsal practice, of explicit consideration of how the conditions modelled would be recognised, recorded, and responded to as incidents. The rehearsal's three movements end with a description of the residual operating posture. A fourth, optional movement asks what would happen if the conditions modelled occurred without warning - who would notice, what would be declared, who would lead the response, what would be reported and to whom. The answer, in many cases, is that the conditions would not be recognised as an incident at all because no existing category fits them. The recognition of this gap, in the context of a specific rehearsal, is more valuable than any premature attempt to fill it.

7.5 The intellectual task ahead

The development of an adequate vocabulary for compositional incidents is, in this author's view, one of the more pressing intellectual tasks facing the architecture, security, and governance communities. The conditions that produce compositional incidents are not transient. They are properties of the systems we have built and the environment in which those systems operate. The vocabulary will be developed by the field over the coming years; it will not be developed by any single contribution, including this one. What is offered here is the recognition that the development is necessary, the working definition against which the field can react, and the practices through which practitioner experience can be accumulated to inform that development.

The honest position, at this stage of the field's development, is that the framework is more complete in its description of the conditions under which compositional incidents arise - through the jurisdictional architecture drawing, the strategic exposure register, and the contestability rehearsal - than in its prescription for how such incidents are to be recognised and addressed when they occur. That asymmetry is acknowledged. It is offered as an invitation to the field rather than concealed as a gap in the framework.

8. Adoption: ninety days, one year, and living with exposure

A framework that cannot be adopted is not a framework. This chapter offers practical guidance on adoption, organised around three horizons: the first ninety days, the first year, and the longer practice of living with exposure. The guidance is given in terms of activities, not technologies. The framework's instruments are designed to be implemented with whatever tools an organisation already has - spreadsheets, drawing software, document repositories, meeting rooms. Specialised tooling may emerge from the practice over time. It is not required to begin.

8.1 The first ninety days

The objective of the first ninety days is to produce, for a single system of strategic importance, the three core artefacts of the framework. The objective is not to produce perfect artefacts. It is to produce artefacts of sufficient quality to support the next stage of practice. A complete imperfect set of artefacts is more valuable than an incomplete perfect set.

1. Select a single system. The system selected should be of strategic importance, well-understood by its operators, and accessible to the team conducting the work. A poor selection - a system that is too peripheral to matter, too complex to understand in the time available, or too inaccessible to examine - will undermine the practice before it has begun. A good selection is a system whose loss would matter, whose architecture is documented, and whose operators are willing to participate.
2. Establish accountability. Identify the senior architect or equivalent who will hold accountability for the framework's introduction. This person is the framework's owner within the organisation for the duration of the adoption. They are not the executor of the work; they are the person whose role makes it possible for the work to proceed.
3. Produce the jurisdictional architecture drawing. Apply the three-pass annotation to the existing technical architecture diagram. Expect the first pass to take a day, the second to take two or three days as corporate structure is investigated, and the third to take a week or more as legal advice is gathered. Record uncertainty explicitly.
4. Conduct a first contestability rehearsal. Select a single triggering action of moderate severity, recognisable to the participants, and traceable through the architecture without specialist legal knowledge. Allow half a day for the rehearsal itself, plus preparation and write-up. The output of the first rehearsal is, in part, calibration for the practice; subsequent rehearsals will be more efficient.
5. Open the strategic exposure register. Populate it from the findings of the jurisdictional architecture drawing and the first rehearsal. Expect six to fifteen entries from the first system, of which several will have blank or speculative fields. This is normal and is itself a finding.

6. Report. Produce, at the close of the ninety days, a short report for the senior accountable governance body summarising the artefacts produced, the exposures identified, and the proposed next steps. The report should be honest about what is not yet known.

8.2 The first year

The objective of the first year is to establish the framework's practice across a portfolio of systems and to integrate it with existing governance. The framework should, by the end of the year, be a recognisable practice within the organisation with identifiable owners, regular outputs, and an established relationship to the conventional risk and architecture functions.

- Extend coverage. By month six, jurisdictional architecture drawings should exist for the principal systems of strategic importance, prioritised by criticality. By month twelve, coverage should extend to all systems whose loss would constitute a strategic concern for the organisation.
- Establish rehearsal cadence. By month nine, a regular cadence of contestability rehearsals should be established, with two or three rehearsals per year for systems of strategic importance and additional rehearsals on a thematic basis - rotating through actor classes, mechanisms, or composition patterns.
- Integrate with risk governance. By month twelve, the strategic exposure register should be a recognised input to the organisation's risk governance, with established relationships to the conventional risk register, the architecture review board, and the audit function. Tensions at the interface should be expected and managed; the integration is not a merger.
- Develop facilitation capability. The framework's practice depends on skilled facilitation of rehearsals. Identify and develop facilitators within the organisation. External facilitators may be appropriate for the most sensitive rehearsals; internal capability should not depend on them.
- Connect to procurement. The framework's findings should, by the end of the year, be informing procurement decisions. Specifically, the jurisdictional architecture drawing should be consulted before new components are introduced, and the strategic exposure register should be considered in any major procurement of strategic relevance.

8.3 Living with exposure

An honest treatment of the framework must address what an organisation does about exposures that the practice reveals and that cannot straightforwardly be remediated. In most cases, the answer is not to rip and replace. The components that produce strategic exposures are often the same components that deliver the organisation's principal capabilities. Remediation, where it is possible, is rarely fast, rarely cheap, and rarely complete. Living with exposure - operating knowingly, with eyes open, with appropriate residual posture and

appropriate mitigations - is the realistic condition for most organisations for most exposures for some time to come.

Living with exposure has several disciplines. The first is acknowledgement. An exposure that is known is not the same as an exposure that is denied. Acknowledged exposures can be governed; denied exposures cannot. The second is documentation. The strategic exposure register, properly maintained, is the principal instrument of acknowledgement. The third is monitoring, to the extent possible - developing observable signatures where they can be developed, accepting their absence where they cannot, and recording the difference. The fourth is preparation: ensuring that the residual operating posture is known, that the people who would need to operate it are aware, and that, where feasible, the posture has been exercised.

The fifth discipline is the hardest. It is the discipline of accepting that some exposures are not yet remediable, of recording this honestly, and of communicating it to the governance levels that need to know without sliding into either alarm or complacency. The framework's instruments are designed to support this communication by giving the exposures a specific, structured, documentary form that resists both the dismissal that vague exposures invite and the alarm that undocumented exposures provoke.

8.4 Signs the practice is taking hold

An organisation can know that the practice is taking hold when several signs become observable. The jurisdictional architecture drawing is consulted in design reviews. The strategic exposure register is referenced in board papers. Contestability rehearsals produce findings that change subsequent procurement decisions. The vocabulary of resilience, sovereignty, and contestability is used precisely in conversations where it would previously have been used loosely. The phrase 'we have never thought about that' becomes less frequent in architectural conversations, and the phrase 'we considered that during the last rehearsal' becomes more frequent. The framework's instruments become part of how the organisation thinks, not separate exercises that the organisation conducts.

An organisation can know that the practice is not yet taking hold when the artefacts exist but are not consulted, when the rehearsals are conducted but their findings are not acted on, when the register is maintained but is not read, or when the vocabulary is used in framework-related contexts but not in the wider conversations of the organisation. In such cases the practice has been adopted in form but not in substance. The remedy is not more framework.

The remedy is sustained leadership attention to the connection between the framework and the decisions it should be informing.

9. Coda: an open framework

The Strategic Architecture Framework is offered openly. The intent is not to establish a methodology, to certify practitioners, or to monetise practice. The intent is to contribute a starting point to a field that needs one, and to do so in a form that the field can adopt, adapt, and extend on its own terms.

What is offered here is a vocabulary, a positioning of the proposed discipline against the adjacent disciplines, three artefacts, a working definition of compositional incidents as an open problem, and a proposed approach to adoption. What is not offered, and cannot be offered by any single document, is the accumulated experience of the field. That experience will be developed by practitioners - in government, in critical infrastructure, in defence-adjacent industry, in the regulatory community, and in the academic literature - and the framework will improve as a result. Practitioners are invited to use what is useful, to discard what is not, to extend where extension is needed, and to write back about what they find.

Several extensions are visible from the present vantage and are signalled here as candidates for the field's attention. The development of a richer notation for the jurisdictional architecture drawing, capable of capturing supranational reaches, dynamic ownership structures, and contested legal instruments. The development of further artefact patterns for the strategic exposure register, addressing classes of exposure not adequately covered by the structure proposed here. The development of facilitation guidance for contestability rehearsals at scale, including for rehearsals that span organisational boundaries. The development of an actual vocabulary, not merely a working definition, for compositional incidents - the open problem this paper identifies and does not solve. The development of training and certification, if and when the field judges that it requires them, conducted by appropriate bodies rather than by any single author. The relationship between the framework and the regulatory environment in which it would be most useful, including the question of whether and how regulators should incorporate strategic architectural concerns into their existing instruments.

The framework will live or fail by its utility. If it makes the conditions it addresses more visible, more discussable, and more governable, it will have served its purpose. If it does not, better tools should be developed and this one set aside. The condition the framework addresses is not waiting for the field to perfect its instruments. The condition is present now, in systems of consequence, in organisations that do not yet have the means to examine it. The work of the next decade, for those of us responsible for systems of consequence, is to look honestly at what we have, to draw the maps we have not drawn, to keep the registers we have not

kept, to rehearse the conditions we have not rehearsed, and to develop the vocabulary the field needs and does not yet possess.

We built much of this when we were not looking. Looking is the work that remains.

ENDS